

GCP:

Database Elevate Privilege & Remote Code Execution

Platform:

AlloyDB for PostgreSQL

Class:

Remote Code Execution

Summary:

I found a new database elevate privilege problem in PostgreSQL which can make me to be superuser in database. With superuser's role and a code execution supported by extension file_fdw, I can get a code execution over PostgreSQL container. There is a risk that the host directory / is mounted to /host in PostgreSQL container. And The service account exposed via the metadata service has excessive scopes with

<https://www.googleapis.com/auth/cloud-platform>.

Attack Description:

Phase I: Get superuser's role of database

The new vulnerabilities is existed in extension “postgres_fdw”, which can be used to get superuser’s role (alloydbadmin).

- **The problem in extension postgres_fdw which I called Validation Bypass Attack.**
 1. Create a AlloyDB postgres database with extensions postgres_fdw enabled. Connect in database postgres.
 2. Create a FOREIGN DATA Server local_pgs , then replace function postgres_fdw_validator, local_pgs server's host is a domain resolving to 127.0.0.11.
 3. Create USER MAPPING with options that user is alloydbadmin and password_required is false.
 4. Create a view with a function that alter postgres with superuser.
 5. Create a foreign table pointing to the view created in the previous step and select from the foreign table.

[illegible]

Superuser with postgres

The root cause of this problem is that alloydbsuperuser's function operation privileges are too broad.

Phase II: Code execution over PostgreSQL container

There are many ways to get code execution with PostgreSQL, in this time I use extension `file_fdw` as command execution to suite an environment that indirectly utilizes superuser privileges. However, instead of simply using the extension's built-in commands, the restriction imposed by program is bypassed by creating a C function.

total 498496				
drwxr-xr-x	1	root	root	4096 Dec 23 09:09 .
drwxr-xr-x	1	root	root	4096 Dec 23 09:09 ..
-rwxr-xr-x	1	root	root	0 Dec 23 09:09 .dockerenv
drwxr-xr-x	1	root	root	4096 Jan 1 1970 bin
drwxr-xr-x	3	root	root	4096 Dec 25 07:23 conf
drwxr-xr-x	16	root	root	3380 Dec 25 07:23 dev
-r-xr-xr-x	1	root	root	7203 Jan 1 1970 envoy_config_postgres.pb_text
-r-xr-xr-x	1	root	root	460621304 Jan 1 1970 envoy_proxy_server
drwxr-xr-x	1	root	root	700 Dec 25 07:43 etc
drwxr-xr-x	20	root	root	4096 Dec 3 03:55 <u>host</u>
drwxr-xr-x	3	root	root	4096 Jan 1 1970 include
drwxr-xr-x	1	root	root	4096 Jan 1 1970 lib
drwxr-xr-x	2	root	root	4096 Jan 1 1970 lib64
drwxr-xr-x	5	root	root	4096 Sep 27 09:43 mnt
drwxr-xr-x	2	root	root	4096 Jan 1 1970 pkgs
drwxr-xr-x	4	root	root	4096 Jan 1 1970 postgres-scripts
dr-xr-xr-x	2	root	root	4096 Jan 1 1970 postgres17alloydb_image_pkgs
dr-xr-xr-x	348	root	root	0 Dec 25 07:23 proc
-r-xr-xr-x	1	root	root	49745917 Jan 1 1970 proxy_server
drwxr-xr-x	5	root	root	4096 Dec 24 08:49 run
drwxr-xr-x	2	root	root	4096 Jan 1 1970 sbin
drwxr-xr-x	1	root	root	4096 Jan 1 1970 share
dr-xr-xr-x	13	root	root	0 Dec 25 07:23 sys
drwxrwxrwt	1	root	root	4096 Dec 24 08:49 tmp
drwxr-xr-x	1	root	root	4096 Jan 1 1970 usr
dr-xr-xr-x	2	root	root	4096 Jan 1 1970 utils
drwxr-xr-x	11	root	root	4096 Dec 25 07:23 var

Code Execution Example with Command 'ls -al /'

Phase III: Analyze Container

Initially, file-related operations were not permitted. After discovering the `alloydb.fs_access` system parameter and modifying it, the `lo_export` function could be used to write binary data. With busybox support, `wget` can be used directly to retrieve

information from the metadata server. The token can be used to retrieve production images from the container registry, but does not allow image pushes.

```
tags
["cluster-testtianma","instance-uid-2d448966-2e84-459c-bc59-243346ff176e","instance-xf2d-testtianma-primary-2d448966"]
virtual-clock/
zone

service-accounts/
c-761859937504-f20371b1@gcp-sa-alloydb.iam.gserviceaccount.com/
default/

aliases
email c-761859937504-f20371b1@gcp-sa-alloydb.iam.gserviceaccount.com
identity https://www.googleapis.com/auth/cloud-platform
scopes https://www.googleapis.com/auth/cloud-platform
token {"access_token":"ya29.c.c0AYnqXliQ9108s2Tz5e6E0iYAA5pBSTTnYv35r17tRsiN9mXD8KwLWz6IwPe5WbYhbNctRZ3KblvI6A7myD101Kgb7sKmf"}
```

Metadata Server info

REPOSITORY	SIZE	TAG	IMAGE ID	CREATED
gcr.io/cloud-ssa/instance_agent_multiarch	ago 424MB	stable	3e8a0e5349d6	10 days
postgres	ago 453MB	17	6e8b59d5003c	2 weeks
gcr.io/alloydb-prod/logging_agent	ago 392MB	alloydb-dataplane-pg17_20251022.02_RC18	8f6ac0304341	3 weeks
gcr.io/alloydb-prod/ml_agent_v2	ago 394MB	alloydb-dataplane-pg17_20251022.02_RC18	b9c9fee94eff	3 weeks
gcr.io/alloydb-prod/operation_agent	ago 1.77GB	alloydb-dataplane-pg17_20251022.02_RC18	aa522bd45554	3 weeks
gcr.io/alloydb-prod/ml_agent	ago 2.16GB	alloydb-dataplane-pg17_20251022.02_RC18	e1761162ab19	3 weeks
gcr.io/alloydb-prod/memory_agent	ago 635MB	alloydb-dataplane-pg17_20251022.02_RC18	6cf8f686e33f	3 weeks
gcr.io/alloydb-prod/authproxy_server	ago 393MB	alloydb-dataplane-pg17_20251022.02_RC18	8264a622b97c	3 weeks
gcr.io/alloydb-prod/critical_agent	ago 44.7MB	alloydb-dataplane-pg17_20251022.02_RC18	997eec428dd4	3 weeks
gcr.io/alloydb-prod/observability_agent	ago 418MB	alloydb-dataplane-pg17_20251022.02_RC18	b23fc36a98b9	3 weeks
gcr.io/alloydb-prod/postgres17alloydb_service	ago 11.1GB	alloydb-dataplane-pg17_20251022.02_RC18	d9737e4c39bc	3 weeks
gcr.io/speckle-manual-test/alloydb-toolbox	ago 4.52GB	latest	0271411b8522	3 weeks

Images Pulled

```
Linux ga11-testtianma-primary-292828fe-t8n4 6.6.105+ #1 SMP PREEMPT_DYNAMIC Sat Sep 27 08:48:45 UTC 2025 x86_64 GNU/Linux
```

Kernel Version

It's difficult to use kernel vulnerabilities to escalate privileges on this version and I received an alert email. So I stop the exploit here.

Usage:

I will give the poc which name poc-alloydb.sql I have used in attachment. Please pay attention to my comments.

Analyze:

Honestly, the current PostgreSQL Kernel core protections are very secure, but some dangerous extensions like file_fdw and adminpack should be removed. Since users are not supposed to use them, why not eliminate them?